

Nmap – الدليل الشامل للمبتدئين

شرح مفصّل لموديول Nmap في TryHackMe: ال 4 Rooms + ال
Recap، مع حل الأسئلة وملخصات الأوامر

تنبيه قانوني وأخلاقي: كل الأوامر في هذا الدليل مخصصة للتعلّم فقط، وتُستخدم على أجهزة تملكها أو لديك إذن مكتوب بفحصها: مثل بيئات TryHackMe و Hack The Box و CTF والمعامل الشخصية (VMS). فحص شبكات أو أجهزة بدون إذن قد يكون مخالفًا للقانون.

كيف تستخدم هذا الدليل

- ابدأ بقسم **الأساسيات** (القسم 0) إذا كنت جديدًا على الشبكات. اقرأه مرة واحدة فقط وسيسهّل عليك كل ما بعده.
 - كل Room له قسم مستقل بنفس الترتيب: **الفكرة، الأوامر، كيف يعمل من الداخل، منظور المهاجم والمدافع، ثم حل الأسئلة.**
 - الأوامر مكتوبة بالإنجليزية كما تُكتب في ال Terminal. الشرح بالعربية مع إبقاء المصطلحات التقنية بالإنجليزية.
 - **عن حل الأسئلة:** الأسئلة النظرية (مثل: ما هو ال flag؟ ما الأمر؟) أجبت عنها مباشرة. أما الأسئلة العملية التي تطلب نتيجة فحص على جهاز ال Lab فإجابتها تتغير مع كل Instance، لذلك كتبت لك **الأمر المطلوب وطريقة استخراج الإجابة من ال output**، ومكانًا فارغًا لتكتب نتيجتك. هذا هو الأسلوب الذي يبني مهارة حقيقية.
-

جدول المحتويات

1. [أساسيات لازمة قبل البدء](#)
 2. [Room 1: Nmap Live Host Discovery](#)
 3. [Room 2: Nmap Basic Port Scans](#)
 4. [Room 3: Nmap Advanced Port Scans](#)
 5. [Room 4: Nmap Post Port Scans](#)
 6. [Topic Transition Recap: مراجعة شاملة وخطة عمل كاملة](#)
 7. [Cheat Sheet: كل الأوامر في صفحة واحدة](#)
 8. [أخطاء شائعة وحلولها](#)
 9. [المراجع ومصادر التعلم](#)
 10. [قاموس المصطلحات](#)
-

0) أساسيات لازمة قبل البدء

0.1 ما هو Nmap؟

(Network Mapper) **Nmap** أداة مفتوحة المصدر لاكتشاف الأجهزة والخدمات على الشبكة. أنشأها Gordon Lyon (المعروف باسم Fyodor) وهي المعيار الفعلي في الـ Penetration Testing. تجيبك Nmap عن هذه الأسئلة:

السؤال	المرحلة
ما الأجهزة الشغالة (Live Hosts) على الشبكة؟	Host Discovery
ما المنافذ (Ports) المفتوحة على كل جهاز؟	Port Scanning
ما الخدمة ورقم نسختها على كل Port؟	Service / Version Detection
ما نظام التشغيل؟	OS Detection
هل توجد ثغرات أو معلومات إضافية؟	Nmap Scripting Engine (NSE)

المسار المنطقي للفحص (وهو نفس ترتيب الـ Rooms):

Live Host Discovery (Room 1) -> Port Scan (Room 2) -> Advanced/Evasion (Room 3) -> Service + OS + Scripting (Room 4)

0.2 التثبيت والصيغة العامة

```
# Debian / Ubuntu / Kali (على Kali غالبًا مثبتة مسبقًا على)
sudo apt update && sudo apt install nmap -y

# التحقق من النسخة
nmap --version
```

الصيغة العامة:

```
nmap [Scan Type] [Options] {target}
```

أمثلة على الـ {target} :

```

nmap 10.10.10.5          # جهاز واحد
nmap scanme.nmap.org      # اسم نطاق (Domain)
nmap 10.10.10.1-20        # نطاق من الأجهزة
nmap 10.10.10.0/24        # شبكة كاملة بصيغة CIDR
nmap -iL targets.txt      # قراءة الأهداف من ملف

```

ملاحظة: الموقع scanme.nmap.org يسمح فريق Nmap بفحصه بشكل خفيف للتجربة، ولا تُسيء استخدامه.

0.3 لماذا نستخدم `sudo` مع Nmap؟

كثير من أنواع الفحص تحتاج إرسال **Raw Packets** (حزم مصنوعة يدويًا) وهذا يتطلب صلاحيات `root`.

الحالة	ما يحدث
تشغل Nmap بصلاحيات <code>root</code>	يستخدم الأسرع والأقوى: <code>-ss</code> (SYN Scan) و <code>ARP</code> على الشبكة المحلية
تشغل Nmap بدون <code>root</code>	يستخدم <code>-sT</code> (TCP Connect Scan) لأنه لا يحتاج Raw Sockets

0.4 مفاهيم الشبكات الأساسية

(أ) طبقات TCP/IP

الطبقة	وظيفتها	أمثلة	أين يظهر في Nmap؟
Application	بروتوكولات التطبيقات	HTTP, FTP, DNS, SSH	Service Detection و NSE
Transport	توصيل البيانات بين تطبيقين عبر Ports	TCP, UDP	Port Scans
Internet	العناوين والتوجيه (Routing)	IP, ICMP	ICMP Ping, Traceroute
Link (Network Access)	التواصل داخل الشبكة المحلية بعناوين MAC	Ethernet, Wi-Fi, ARP	ARP Scan

حفظ سريع: ARP يعمل في طبقة IP. Link و ICMP في طبقة TCP. Internet و UDP في طبقة Transport.

(ب) بروتوكول ARP

الجهاز يعرف IP الهدف لكن لا يعرف MAC. فيرسل (Broadcast) **ARP Request** يقول: "من يملك هذا الـ IP؟ أخبرني". الجهاز صاحب الـ IP يرد **ARP Reply** بعنوان الـ MAC. (هذا ما رأيته في الـ Lab الذي يسبق هذه الـ Rooms: **Who has router tell computer2**).

نقطتان مهمتان لـ ARP: 1. Nmap لا يعمل إلا داخل **نفس الشبكة المحلية (Subnet)**، فهو لا يُوجّه عبر الـ Router. 2. لا يستطيع جهاز على الشبكة المحلية أن يتجاهل ARP بسهولة؛ لذلك هو أدق طريقة لاكتشاف الأجهزة المحلية، حتى لو كان الـ Firewall يحجب Ping.

(ج) بروتوكول ICMP

بروتوكول للرسائل التشخيصية. أشهر رسائله لنا:

Type	الاسم	الاستخدام
8	Echo Request	هو الـ ping
0	Echo Reply	رد الـ ping
14 / 13	Timestamp Request / Reply	سؤال الجهاز عن وقته
18 / 17	Address Mask Request / Reply	سؤال الجهاز عن الـ Subnet Mask
3	Destination Unreachable	رسالة خطأ، منها (Code 3) Port Unreachable

(د) بروتوكول TCP: المصافحة الثلاثية (3-Way Handshake)

TCP بروتوكول موثوق يبني اتصالاً قبل إرسال البيانات:

Client	Server
----- SYN ----->	"أريد أن أتصل"
<----- SYN + ACK -----	"موافق، وأنا أيضاً أريد الاتصال"
----- ACK ----->	"تم، الاتصال قائم"

أعلام (TCP Flags) وهي أساس فهم كل أنواع الفحص:

Flag	معناه
SYN	بدء اتصال (Synchronize)
ACK	تأكيد استلام (Acknowledge)
FIN	إنهاء الاتصال بشكل طبيعي
RST	قطع الاتصال فورًا / رفض (Reset)
PSH	ادفع البيانات للتطبيق مباشرة (Push)
URG	البيانات عاجلة (Urgent)

القاعدة الذهبية لفهم الفحص: عندما تُرسل SYN إلى Port: - مفتوح - < يرد **SYN/ACK** - مغلق - < يرد **RST** - يوجد Firewall يحجب - < لا يرد شيء، أو يرد رسالة ICMP خطأ

(هـ) بروتوكول UDP

UDP **بدون اتصال** (Connectionless): يرسل ولا ينتظر تأكيدًا. أسرع لكنه غير موثوق. يُستخدم في DNS و DHCP و SNMP و VoIP. هذا يجعل فحصه **أبطأ وأصعب** لأن المنفذ المفتوح غالبًا لا يرد شيئًا (سنشرح هذا في Room 2).

(و) المنافذ (Ports) الشائعة التي يجب أن تحفظها

Port	البروتوكول	الخدمة
20/21	TCP	FTP
22	TCP	SSH
23	TCP	Telnet
25	TCP	SMTP
53	UDP (و TCP)	DNS
67/68	UDP	DHCP
80	TCP	HTTP
110	TCP	POP3
111	TCP/UDP	RPCbind
123	UDP	NTP
445 / 139	TCP	NetBIOS / SMB
143	TCP	IMAP
161	UDP	SNMP
443	TCP	HTTPS
3306	TCP	MySQL
3389	TCP	RDP

عدد الـ Ports في كل بروتوكول **65,535** (من 1 إلى 65535). و Ports من 1 إلى 1023 تُسمى **Well-Known Ports**.

0.5 كيف تقرأ مخرجات Nmap؟

المثال التالي توضيحي (ليس من الـ Lab):

```

$ sudo nmap -sS 10.10.10.5
Nmap scan report for 10.10.10.5
Host is up (0.00045s latency).          <-- (1) الجهاز شغال
Not shown: 996 closed tcp ports (reset) <-- (2) ملخص الباقي
PORT      STATE SERVICE                                <-- (3) الجدول الرئيسي
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 02:AB:CD:12:34:56 (Unknown) <-- (4) يظهر فقط على الشبكة المحلية
Nmap done: 1 IP address (1 host up) scanned in 1.52 seconds

```

1. **Host is up**: وصلنا رد من الجهاز. إن رأيت **Host seems down** فقد يكون ال Firewall يحجب ال Ping (الحل: الخيار **-Pn**).
2. **Not shown**: ال Ports التي لم تُعرض لأنها في حالة واحدة شائعة، وبجانبها السبب (**reset**) يعني أن الجهاز رد بـ RST).
3. **الأعمدة**: رقم المنفذ/البروتوكول، الحالة (STATE)، والخدمة المُخَمَّنة من رقم المنفذ (وليست مؤكدة إلا مع **-sV**).
4. **MAC Address**: يظهر فقط حين يكون الهدف على نفس الشبكة المحلية.

Room 1: Nmap Live Host Discovery (1

الهدف: قبل فحص ال Ports، نحتاج معرفة أي الأجهزة شغالة على الشبكة. فحص 65 ألف Port على جهاز مطلقاً مضيعة للوقت. هذا ال Room يشرح 4 طرق لاكتشاف الأجهزة: **ARP, ICMP, TCP, UDP**.

1.1 تحديد الأهداف (Enumerating Targets)

حساب نطاقات CIDR

ال $N/2$ CIDR يعني أن أول N بت ثابتة (Network) والباقي (N - 32) متغيرة (Hosts).

CIDR	Subnet Mask	عدد العناوين
8/	255.0.0.0	16,777,216
16/	255.255.0.0	65,536
24/	255.255.255.0	256
29/	255.255.255.248	8
32/	255.255.255.255	1 (جهاز واحد)

القانون: عدد العناوين = $2^{(N - 32)}$.

طرق كتابة الأهداف في Nmap

الصيغة	مثال	المعنى
جهاز واحد	<code>nmap 10.10.10.5</code>	
Hostname	<code>nmap example.com</code>	يحوّله لـ IP عبر DNS
مدى (Range)	<code>nmap 10.10.10.10-20</code>	من 10. إلى 20.
مدى متعدد	<code>nmap 10.10.0-255.101-125</code>	أكثر من Octet
CIDR	<code>nmap 10.10.10.0/24</code>	شبكة كاملة
ملف	<code>nmap -iL list.txt</code>	كل سطر هدف
استثناء	<code>nmap 10.10.10.0/24 --exclude 10.10.10.1</code>	

الخيار (List Scan) -sL : أفضل صديق للحسابات

يعرض الأهداف **بدون إرسال أي حزمة للأجهزة نفسها**. يفيدك للتأكد من النطاق قبل الفحص الفعلي (ويحاول عمل Reverse DNS إلا إذا أضفت `-n`).

```
nmap -sL -n 10.10.12.13/29
```

1.2 الأنواع الأربعة لاكتشاف الأجهزة

الخيار `-sn` معناه: **"لا تفحص الـ Ports"** (Host Discovery فقط). كان اسمه قديمًا "Ping Scan". نستخدمه مع خيارات النوع.

السلوك الافتراضي لـ Nmap عند اكتشاف الأجهزة: - أنت `root` + الهدف على نفس الشبكة المحلية: يستخدم `ARP`. - أنت `root` + الهدف في شبكة بعيدة: يرسل ICMP Echo
TCP SYN + إلى 443 + TCP ACK إلى 80 + ICMP Timestamp. - بدون `root`: يحاول TCP Connect على المنافذين 80 و 443.

النوع 1: ARP Scan (الخيار -PR)

```
sudo nmap -PR -sn 192.168.0.0/24
```

- **الأدق** على الشبكة المحلية، لأنه لا يمكن تجاهله بسهولة، حتى لو كان الجهاز يحجب Ping.
- يحتاج `root`.

- لا يعمل خارج ال Subnet لأن ARP لا يُوجَّه عبر ال Routers.
- أداة مكملة: `arp-scan`.

```
sudo arp-scan -l # الافتراضي interface فحص الشبكة المحلية للـ
sudo arp-scan --localnet
sudo arp-scan -I eth0 -l # interface تحديد الـ
sudo arp-scan -l | less # للمراجعة
```

النوع 2: ICMP Scan

ثلاث طرق:

الخيار	نوع الرسالة	ملاحظات
-PE	Echo Request (Type 8)	هو ال ping التقليدي. غالبًا محجوب في ال Firewalls
-PP	Timestamp Request (Type 13)	قد يمر حين يُحجب Echo
-PM	Address Mask Request (Type 17)	قد يمر حين يُحجب Echo

```
sudo nmap -PE -sn 10.10.10.0/24 # Echo
sudo nmap -PP -sn 10.10.10.0/24 # Timestamp
sudo nmap -PM -sn 10.10.10.0/24 # Address Mask
```

ملاحظة: حتى لو لم تكن الشبكة ترد على Echo، جرِّب Timestamp و Address Mask، فقد يكون الأدمن نسي حبيهما.

النوع 3: TCP Ping

الخيار	ما يُرسل	الاستنتاج	يحتاج root؟
-PS[ports]	SYN	رد SYN/ACK أو RST = الجهاز شغال	لا (يستخدم connect())
-PA[ports]	ACK	رد RST = الجهاز شغال	نعم

```
sudo nmap -PS -sn 10.10.10.0/24 # SYN إلى Port 80 (الافتراضي)
sudo nmap -PS23 -sn 10.10.10.0/24 # SYN إلى Port 23 (Telnet)
sudo nmap -PS21-25,80,443 -sn 10.10.10.0/24
sudo nmap -PA -sn 10.10.10.0/24 # ACK إلى Port 80
```

كيف يعمل؟ سواء كان ال Port مفتوحًا أو مغلقًا، الجهاز سيرد بشيء (SYN/ACK أو RST). وأي رد يثبت أنه حيّ. ال ACK Ping يخدع Firewalls التي تحجب SYN فقط، لأن حزمة ACK تبدو كجزء من اتصال قائم، فيرد الجهاز بـ RST.

النوع 4: UDP Ping (الخيار -PU)

```
sudo nmap -PU -sn 10.10.10.0/24
sudo nmap -PU53 -sn 10.10.10.0/24
```

- يرسل حزمة UDP إلى Port (غالبًا مغلق).
- إن كان الجهاز حيًا يرد **ICMP Port Unreachable**، وهذا يثبت أنه شغّال.
- إن لم يرد شيء، لا نعرف (قد يكون مطفأ أو يحجب).

أداة masscan (للسرعة العالية)

```
masscan 10.0.0.0/8 -p443 --rate 1000
```

أسرع من Nmap بكثير لأنها تستخدم TCP/IP stack خاص بها، لكنها أقل دقة وأقل مميزات. تُستخدم لمسح نطاقات ضخمة. **استخدمها فقط على أهداف مسموح بها.**

1.3 DNS: خيارات -R و -n

Nmap يحاول افتراضيًا عمل **Reverse DNS** للأجهزة الشغّالة فقط (IP -> Hostname) لأن الأسماء تكشف معلومات (مثل dc01 , db-server).

الخيار	الوظيفة
-n	لا تعمل DNS lookup أبدًا (أسرع وأهدأ)
-R	اعمل Reverse DNS لكل ال IPs حتى التي تبدو مطفأة
--dns-servers 8.8.8.8	استخدام DNS Server محدد

1.4 منظور المهاجم والمدافع

المهاجم (Red Team)	المدافع (Blue Team)
ما يفعله يبدأ بـ ARP على الشبكة المحلية لأنه الأدق. ويجرب أكثر من نوع حين يُحجب ICMP	يراقب موجات ARP الكثيفة (أدوات مثل arpwatch) وحزم SYN/ICMP المتتالية على نطاق واسع
نقطة الضعف / القوة ARP صوته عالٍ على الشبكة المحلية	حجب Echo وحده لا يكفي، يجب مراقبة Timestamp و Address Mask أيضًا

1.5 ملخص خيارات الـ Room

الخيار	الوظيفة
-sL	اعرض الأهداف فقط (بدون فحص)
-sn	اكتشاف الأجهزة فقط (بدون فحص Ports)
-PR	ARP Scan
-PE / -PP / -PM	ICMP: Echo / Timestamp / Address Mask
-PS / -PA	TCP SYN Ping / TCP ACK Ping
-PU	UDP Ping
-R / -n	بدون DNS / DNS لكل الأجهزة
-Pn	تخطي الاكتشاف واعتبر كل الأجهزة شغالة

1.6 حل أسئلة الـ Room 1

الأسئلة النظرية (إجاباتها ثابتة)

السؤال	الإجابة	التفسير
ما أول IP يفحصه Nmap إذا كان الهدف 10.10.12.13/29 ؟	10.10.12.8	29/ = 8 عناوين، الكتلة التي تضم 13. هي من 8. إلى 15، وأولها 8.
كم IP سيفحص Nmap للنطاق 10.10.0-255.101-125 ؟	6400	$6400 = (25) \times (256)$
خيار ARP Scan	-PR (مع -sn)	
خيار ICMP Echo	-PE	
خيار ICMP Timestamp	-PP	
خيار ICMP Address Mask	-PM	
خيار TCP SYN Ping	-PS	
خيار TCP ACK Ping	-PA	
خيار UDP Ping	-PU	
لعمل TCP SYN Ping على منفذ Telnet	-PS23	Telnet = Port 23
أي TCP Ping يحتاج صلاحيات root ؟	TCP SYN Ping	
أي TCP Ping يحتاج صلاحيات root ؟	TCP ACK Ping	
أداة الفحص الأسرع المذكورة	masscan	
خيار عمل Reverse DNS لكل الأجهزة	-R	
خيار منع DNS lookup	-n	
ARP في أي طبقة TCP/IP ؟	Link	
ICMP و IP في أي طبقة ؟	Internet	
TCP و UDP في أي طبقة ؟	Transport	

طريقة التحقق بنفسك من الحسائين الأولين:

```
nmap -sL -n 10.10.12.13/29 | head -n 3
nmap -sL -n 10.10.0-255.101-125 | tail -n 1
```

```
# أول IP
# آخر سطر: "Nmap done: 64
```

الأسئلة العملية (تعتمد على الـ Lab الخاص بك)

ما يطلبه السؤال	الأمر	كيف تستخرج الإجابة
عدد الأجهزة التي تردّ على ARP	<code>sudo nmap -PR -sn MACHINE_IP/24</code>	آخر سطر: <code>Nmap done: 256 IP addresses (N hosts up)</code>
عدد الأجهزة التي تردّ على ICMP Echo	<code>sudo nmap -PE -sn MACHINE_IP/24</code>	نفس الطريقة
عدد الأجهزة التي تردّ على ICMP Timestamp	<code>sudo nmap -PP -sn MACHINE_IP/24</code>	نفس الطريقة
عدد الأجهزة التي تردّ على TCP SYN / ACK	<code>sudo nmap -PS -sn ...</code> و <code>-PA</code>	نفس الطريقة
عدد الأجهزة في Subnet معيّن	<code>sudo nmap -sn SUBNET/24</code>	نفس الطريقة
اسم الـ Hostname المعاد من DNS	<code>nmap -R -sn MACHINE_IP/24</code>	يظهر بجانب الـ IP

ملاحظة: حين يطلب السؤال عدد الأجهزة، اقرأ عبارة `(N hosts up)` . وإن اختلفت نتيجتك بين الأنواع، فهذا طبيعي: كل Firewall يحجب نوعًا مختلفًا.

Room 2: Nmap Basic Port Scans (2

الهدف: بعد معرفة الأجهزة الحيّة، نكتشف أي **Ports مفتوحة** وما يعنيه ذلك. هنا نتعلّم الفحوصات الأساسية الثلاثة: **TCP Connect, TCP SYN, UDP**، ثم كيف نتحكم بنطاق الفحص وسرعته.

2.1 حالات ال Port الست (Port States)

هذا أهم جدول في ال Room كله. Nmap يصنّف كل Port في واحدة من **6 حالات**:

الحالة	المعنى	ماذا حدث؟
open	يوجد خدمة تستمع وتقبل الاتصال	وصل رد إيجابي (مثل SYN/ACK)
closed	ال Port يستجيب لكن لا توجد خدمة	وصل رد RST
filtered	Nmap لا يعرف، لأن شيئاً (Firewall) يمنع وصول الحزم	لا رد، أو ICMP error
unfiltered	ال Port يمكن الوصول إليه لكن Nmap لا يعرف هل هو مفتوح أم مغلق	يظهر في فحص ACK فقط
open filtered	Nmap لا يستطيع التفريق بين مفتوح ومحجوب	لا رد (شائع في UDP و Null/FIN/Xmas)
closed filtered	لا يستطيع التفريق بين مغلق ومحجوب	نادر (يظهر في Idle Scan)

تذكّر: **closed** ليست مشكلة بل معلومة: الجهاز حيّ وبلا Firewall على هذا ال Port. أما **filtered** فهي الإشارة الأولى لوجود Firewall.

2.2 TCP Connect Scan (الخيار -sT)

```
nmap -sT 10.10.10.5
```

كيف يعمل: يُكمل ال 3-Way Handshake كاملاً ثم يقطع الاتصال، تمامًا كما يفعل أي برنامج عادي.

المنفذ مغلق

```
Nmap --SYN-----> Target
Nmap <--SYN/ACK---- Target
Nmap --ACK-----> Target
Nmap --RST/ACK ---> Target
(الحالة: open)
```

المنفذ مفتوح

```
Nmap --SYN-----> Target
Nmap <--RST----- Target
(الحالة: closed)
```

المميزات	العيوب
لا يحتاج root	صاحب: تسجله الخدمة في الـ Logs (لأن الاتصال اكتمل)
يعمل في أي مكان	أبطأ من SYN Scan

2.3 TCP SYN Scan (الخيار "Half-Open" – "ss" أو "Stealth" Scan

```
sudo nmap -sS 10.10.10.5
```

كيف يعمل: يرسل SYN فقط. فإن رد الهدف بـ SYN/ACK، يقطع Nmap الاتصال فورًا بـ **RST** قبل إكمال المصافحة.

محبوب

المنفذ مغلق

```
Nmap --SYN-----> Target
Nmap <--SYN/ACK---- Target
Nmap --RST-----> Target
(open)
```

المنفذ مفتوح

```
Nmap --SYN-----> Target
Nmap <--RST----- Target
(closed)
(filtered)
```

المميزات	العيوب
أسرع من Connect	يحتاج root (Raw Packets)
أخفى: لا يكمل الاتصال فلا تسجله بعض التطبيقات	لا يختفي من الـ Firewalls و IDS الحديثة
الافتراضي عند تشغيل Nmap بـ root	

لماذا يُسمّى "Stealth"؟ لأن التطبيق لا يرى اتصالاً مكتملاً. اليوم الـ IDS و Firewalls تكتشفه بسهولة، فالتسمية تاريخية أكثر من كونها حقيقية.

2.4 UDP Scan (الخيار -sU)

```
sudo nmap -sU 10.10.10.5
sudo nmap -sU --top-ports 20 10.10.10.5    # أسرع: أشهر 20 منفذًا فقط
```

كيف يعمل: يرسل حزمة UDP إلى الـ Port.

الرد	الحالة
رد من الخدمة (UDP)	open
لا رد إطلاقًا	open filtered (قد يكون مفتوحًا لا يرد، أو محجوبًا)
ICMP Port Unreachable (Type 3, Code 3)	closed
ICMP Unreachable أخرى (Codes 1, 2, 9, 10, 13)	filtered

لماذا UDP بطيء؟ لأن Linux يحدّ معدل رسائل ICMP (حوالي 1 في الثانية)، فمعرفة الـ closed تأخذ وقتًا. وعدم الرد يجعل Nmap يعيد المحاولة. لذلك **لا تفحص كل UDP Port 65535** بل استخدم **--top-ports**.

نصيحة: كثير من خدمات UDP لا ترد إلا على بيانات صحيحة. لذلك Nmap يرسل Payloads خاصة لبعض المنافذ المعروفة (مثل DNS و SNMP). ولذلك الفحص مع **-sV** أدق في UDP.

أهم خدمات UDP للبحث عنها في الـ CTF: DNS (53), SNMP (161), TFTP (69), NTP (123), DHCP (67/68).

2.5 التحكم في نطاق الفحص (Scope)

بدون تحديد، Nmap يفحص **أشهر Port 1000** فقط (وليست الأرقام من 1 إلى 1000!).

الخيار	الوظيفة
-p22	Port واحد
-p22,80,443	عدة Ports
-p1-1023	مدى
-p-	كل الـ 65535 Port
-F	Fast : أشهر 100 Port
--top-ports 10	أشهر N Port
-r	بترتيب تصاعدي (بدل العشوائي)
--open	اعرض المفتوح فقط

```

sudo nmap -sS -p- 10.10.10.5 # CTF (الأفضل في) Ports كل الـ
sudo nmap -sS -p22,80,443 10.10.10.5
sudo nmap -sS --top-ports 10 10.10.10.5
sudo nmap -F 10.10.10.5

```

2.6 التحكم في السرعة (Timing and Performance)

قوالب التوقيت **-T0** إلى **-T5**

القالب	الاسم	الاستخدام
-T0	paranoid	بطيء جدًا (انتظار دقائق بين كل حزمة)، للتهرب من IDS
-T1	sneaky	بطيء، للتهرب
-T2	polite	يخفف الحمل على الهدف
-T3	normal	الافتراضي
-T4	aggressive	سريع. الأنسب للـ CTF والشبكات الجيدة
-T5	insane	الأسرع، لكنه قد يعطي نتائج خاطئة أو يُسقط الاتصال

يمكن كتابتها بالاسم أو بالرقم: **-T4** أو **-T aggressive**.

خيارات دقيقة

الخيار	الوظيفة
--min-rate 100	أرسل على الأقل 100 حزمة/ثانية
--max-rate 50	لا ترسل أكثر من 50 حزمة/ثانية
--min-parallelism 100	عدد أدنى من الفحوصات المتزامنة
--max-parallelism 1	فحص واحد في كل مرة (بطيء ولطيف)
--max-retries 1	عدد إعادة المحاولات
--host-timeout 5m	تخلّ عن الجهاز بعد 5 دقائق

نصيحة عملية: --min-rate 5000 مع -p- يختصر فحص كل ال Ports من دقائق إلى ثوانٍ في ال Labs. لكن في الشبكات الحقيقية قد يُسقط الحزم أو يُنبّه ال IDS.

2.7 منظور المهاجم والمدافع

المهاجم	المدافع
اختيار النوع -sS الأسرع. -sT إذا لا يملك root. su لخدمات تُنسى مثل SNMP و TFTP	يرصد عدد كبير من SYN بدون ACK أو اتصالات Half-Open، وكثرة RST من مصدر واحد
الدفاع الأقوى	Default Deny: افتح فقط ما تحتاجه، وراقب ال Logs. ولا تنسَ UDP!

2.8 حل أسئلة ال Room 2

الأسئلة النظرية

السؤال	الإجابة
كم عدد حالات الـ Port التي يعرفها Nmap؟	6 (open, closed, filtered, unfiltered, open filtered, closed filtered)
أي خدمة تستخدم UDP Port 53؟	DNS
أي خدمة تستخدم TCP Port 22؟	SSH
أي خدمة تستخدم TCP Port 80؟	HTTP
ما اسم الـ flag الذي يعني "Reset"؟	RST
ما الـ flag الذي يعني "Acknowledge"؟	ACK
ما الـ flag الذي يبدأ الاتصال؟	SYN
خيار TCP Connect Scan	-sT
خيار TCP SYN Scan	-sS
خيار UDP Scan	-sU
أي فحص يحتاج -sT أم -sS ؟	-sS (يحتاج Raw Packets)
ما الرد المتوقع من Port TCP مغلق على SYN؟	RST (غالبًا RST/ACK)
ما الرد المتوقع من UDP Port مغلق؟	ICMP Port Unreachable
خيار فحص أشهر Port 100	-F
خيار فحص كل الـ Ports	-p-
خيار فحص أشهر Ports 10	--top-ports 10
قالب -T4	aggressive
قالب -T5	insane
قالب -T0	paranoid
خيار تحديد أقل معدل إرسال	--min-rate
خيار تحديد أعلى معدل إرسال	--max-rate

الأسئلة العملية (تعتمد على الـ Lab الخاص بك)

ما يطلبه السؤال	الأمر	كيف تستخرج الإجابة
أي Ports مفتوحة؟	<code>sudo nmap -sS -p- --open MACHINE_IP</code>	اقرأ عمود PORT بحالة open
أي Port مفتوح في مدى معين؟	<code>sudo nmap -sS -p1-1023 MACHINE_IP</code>	
ما الخدمة على Port معين؟	<code>sudo nmap -sV -p PORT MACHINE_IP</code>	عمود SERVICE و VERSION
هل ظهر Port في حالة filtered؟	<code>sudo nmap -sS MACHINE_IP</code>	ابحث عن filtered
UDP Ports مفتوحة	<code>sudo nmap -sU --top-ports 100 MACHINE_IP</code>	ابحث عن open (و open\ filtered)
كم Port في حالة معينة؟		اقرأ السطر Not shown: N ...

حيلة لمعرفة السبب: أضف `--reason` لتعرف لماذا اعتبر Nmap الـ Port مفتوحًا أو مغلقًا (مثل `syn-ack` أو `reset`).

Room 3: Nmap Advanced Port Scans (3)

الهدف: فحوصات متقدمة تستغل تفاصيل دقيقة في RFC بروتوكول TCP للتهرب من بعض الـ Firewalls البسيطة (Stateless)، بالإضافة إلى تقنيات الـ Spoofing و Idle Scan.

ملاحظة مهمة قبل البدء: الفحوصات في هذا الـ Room (Null, FIN, Xmas) تعمل فقط ضد أنظمة تتبع RFC 793 بدقة. أنظمة **Windows و Cisco غالبًا لا تتبعها** وتردّ RST على كل شيء، فتظهر كل المنافذ "closed" حتى لو كانت مفتوحة. هذه الفحوصات تنجح أكثر ضد أنظمة Unix/Linux القديمة.

3.1 القاعدة الذهبية وراء Null, FIN, Xmas

هذه الفحوصات الثلاثة **لا ترسل SYN إطلاقًا**. بدلًا من ذلك ترسل حزمة "غريبة" لا تنتمي لاتصال قائم، وتعتمد على قاعدة من **RFC 793**:

إذا استقبل أي Port **مغلق** حزمة TCP بدون SYN أو ACK أو RST، يجب أن يرد بـ **RST**. إذا كان الـ Port **مفتوحًا**، يتجاهل الحزمة الغريبة تمامًا (**لا رد**).

لذلك:

النتيجة	الحالة
وصل رد RST	closed
لا رد	open filtered (لا يمكن التفريق بين مفتوح ومحجوب)

3.2 Null Scan (الخيار -sN)

```
sudo nmap -sN 10.10.10.5
```

يرسل حزمة بدون أي **Flags على الإطلاق** (كل البتات = صفر).

3.3 FIN Scan (الخيار -sF)

```
sudo nmap -sF 10.10.10.5
```

يرسل حزمة بها **FIN flag** فقط. الفكرة: FIN تعني "أنهِ الاتصال"، لكن لا يوجد اتصال قائم أصلاً، فمن المفترض أن يرد النظام بـ RST (إن كان ملتزمًا بالـ RFC).

3.4 Xmas Scan (الخيار -sX)

```
sudo nmap -sX 10.10.10.5
```

يرسل حزمة بها **FIN + PSH + URG** معًا. سُميت "Christmas" لأن الحزمة "تضيء" بكل الأعلام مثل شجرة الكريسماس المزينة بالأضواء.

جدول مقارنة سريع:

النوع	الخيار	الأعلام المُرسلة
Null	-sN	(لا شيء)
FIN	-sF	FIN
Xmas	-sX	FIN, PSH, URG

3.5 TCP Maimon Scan (الخيار -sM)

```
sudo nmap -sM 10.10.10.5
```

يرسل **FIN/ACK** معًا. اكتشفه الباحث Uriel Maimon. في بعض أنظمة BSD القديمة، هذا يجعل الفارق واضحًا بين مفتوح ومغلق، لكنه اليوم نادرًا ما يكون مفيدًا ضد أنظمة حديثة.

3.6 TCP ACK Scan (الخيار -sA) — ليس لاكتشاف "مفتوح/مغلق"!

```
sudo nmap -sA 10.10.10.5
```

هذا الفحص **مختلف تمامًا** عن السابقين من حيث الغرض: هو لا يخبرك هل الـ Port مفتوح، بل يُستخدم لرسم خريطة قواعد الـ Firewall (**Firewall Rule Mapping**).

الرد	الاستنتاج
RST	unfiltered — الحزمة وصلت، لا يوجد Firewall يحجبها على هذا الـ Port (لكن لا نعرف مفتوح أم مغلق!)
لا رد / ICMP error	filtered — يوجد شيء يحجب الحزمة

متى تستخدمه؟ لمعرفة هل الـ Firewall **Stateful** (يتتبع حالة الاتصال فيحجب ACK بدون SYN سابق) أم **Stateless** (يفلتر فقط على رقم الـ Port فيسمح لأي ACK بالمرور).

3.7 Custom Scan (الخيار `--scanflags`)

```
sudo nmap --scanflags SYNACK 10.10.10.5
sudo nmap --scanflags SYNFINPSHURG 10.10.10.5
```

يتيح لك **بناء تركيبة أعلام خاصة بك**، لتجربة سلوكيات Firewalls لا تغطيها الأنواع الجاهزة.

3.8 Spoofing و Decoys (التمويه)

IP Spoofing (الخيار `-S`)

```
sudo nmap -S SPOOFED_IP -e eth0 -Pn 10.10.10.5
```

يزوّر عنوان الـ IP المصدر. **المشكلة:** الردود تذهب إلى الـ IP المزوّر وليس إليك، فتفقد رؤية النتيجة إلا بـ Sniffing على شبكة تسمح بذلك (يستخدم غالبًا للتعليم وليس عمليًا على الإنترنت).

Decoys (الخيار `-D`)

```
sudo nmap -D decoy1,decoy2,ME,decoy3 10.10.10.5
sudo nmap -D RND:10 10.10.10.5 # عناوين عشوائية 10
```

يُرسل الفحص الحقيقي مختلطًا بفحوصات وهمية تبدو قادمة من عناوين أخرى (Decoys)، فيصعب على الـ Firewall/IDS معرفة أيّ IP هو المصدر الحقيقي. **ME** تحدد مكان عنوانك الحقيقي بين القائمة.

MAC Spoofing (الخيار `--spoof-mac`)

```
sudo nmap --spoof-mac 00:11:22:33:44:55 10.10.10.5
sudo nmap --spoof-mac Apple 10.10.10.5      # شركة عشوائية
sudo nmap --spoof-mac 0 10.10.10.5          # عشوائي بالكامل
```

يغيّر عنوان الـ MAC المصدر (مفيد فقط على الشبكة المحلية، لأن الـ MAC لا يعبر الـ Routers).

Source Port Spoofing (الخيار -g أو --source-port)

```
sudo nmap -g 53 10.10.10.5
```

يجعل الفحص يبدو وكأنه قادم من Port معروف وموثوق (مثل 53 الخاص بـ DNS)، لخداع Firewalls بسيطة تثق بحركة مرور قادمة من هذا المنفذ.

3.9 Idle (Zombie) Scan — الخيار --scanflags ليس هنا، بل -sI

```
sudo nmap -sI ZOMBIE_IP:PORT TARGET_IP
```

أذكى تقنية في هذا الـ Room للاختفاء التام. تحتاج جهازًا ثالثًا "نائمًا" (**Zombie**) له **IPID تسلسلي** **يسهل التنبؤ به** ولا يُرسل حركة مرور خاصة به في تلك اللحظة.

الفكرة بثلاث خطوات:

```
(RST) الحالي في الرد IPID واحفظ رقم، Zombie إلى الـ SYN/ACK الخطوة 1: أرسل
--SYN/ACK--> Zombie مهاجم
Zombie (IPID = X) <---RST----- مهاجم

Zombie مزورة "للهدف، تدّعي أنها من الـ" SYN الخطوة 2: ابعث حزمة
--SYN (مصدر مزور = Zombie)--> Target مهاجم

الجديد IPID وقارن Zombie ثانياً إلى الـ SYN/ACK الخطوة 3: أرسل
--SYN/ACK--> Zombie مهاجم
Zombie (IPID = ?) <---RST----- مهاجم
```

التفسير: - إن كان Port الهدف **مفتوحًا**: الهدف يرسل SYN/ACK إلى الـ Zombie (لأنه ظن أن الطلب جاء منه)، فيرد الـ Zombie تلقائيًا بـ RST، مما **يزيد IPID بمقدار 2** (حزمة واحدة إضافية أرسلها الـ Zombie). - إن كان Port الهدف **مغلقًا**: الهدف يرسل RST إلى الـ Zombie مباشرة، والـ Zombie **يتجاهله** (لا يرد على RST غير متوقع)، ف **IPID يزيد بمقدار 1 فقط** (الزيادة الطبيعية من خطوتنا نحن).

لماذا هو قوي؟ لأن الهدف لا يرى عنوانك الحقيقي إطلاقًا، بل يرى فقط عنوان الـ Zombie. لكنه يحتاج Zombie مناسبًا (نظام قديم بـ Sequential IPID) وهذا نادر اليوم في الأنظمة الحديثة (تستخدم IPID عشوائي).

3.10 منظور المهاجم والمدافع

المهاجم	المدافع
Null/FIN/Xmas	محاولة تجاوز Firewalls بسيطة Stateless
ACK Scan	Firewall حديث Stateful يحجبها بسهولة بغض النظر عن الأعلام
Decoys/Spoofing	راقب حزم ACK الواردة بدون اتصال SYN سابق لها
Idle Scan	قارن توقيت الحزم من كل الـ IPs — الحقيقي يكون متسقًا زمنيًا
	إخفاء الهوية تمامًا خلف جهاز بريء
	راقب أي جهاز يُستخدم كـ Zombie (طلبات SYN/ACK غير مبررة من IP غريب)

3.11 حل أسئلة الـ Room 3

الأسئلة النظرية

السؤال	الإجابة
خيار Null Scan	-sN
خيار FIN Scan	-sF
خيار Xmas Scan	-sX
خيار Maimon Scan	-sM
خيار ACK Scan	-sA
ما الأعلام في Xmas Scan؟	FIN, PSH, URG
ما الأعلام في Null Scan؟	لا يوجد (صفر أعلام)
ما الرد المتوقع من Port مغلق في Null/FIN/Xmas (حسب RFC 793)؟	RST
ما الرد المتوقع من Port مفتوح في Null/FIN/Xmas؟	لا رد (الحالة: open filtered)
أي أنظمة تشغيل لا تتبع عادة RFC 793 فتفشل معها هذه الفحوصات؟	Windows (وأجهزة Cisco الشبكية)
ما غرض TCP ACK Scan الأساسي؟	رسم خريطة قواعد ال Firewall (معرفة unfiltered/filtered وليس معرفة open/closed)
خيار بناء أعلام مخصصة	--scanflags
خيار تزوير IP المصدر	-S
خيار استخدام عناوين وهمية Decoys	-D
خيار تحديد IPs عشوائية كـ Decoys	-D RND:N
خيار تزوير عنوان MAC	--spoof-mac
خيار تزوير Source Port	-g أو --source-port
خيار Idle / Zombie Scan	-sI
ما الحقل الذي تعتمد عليه تقنية Idle Scan لمعرفة النتيجة؟	IP Identification (IPID)
في Idle Scan، كم تزيد IPID للـ Zombie إذا كان Port الهدف مفتوحًا؟	2

السؤال	الإجابة
في Idle Scan، كم تزيد IPID للـ Zombie إذا كان Port الهدف مغلقًا؟	1
ما الشرط الأساسي في جهاز الـ Zombie؟	IPID تسلسلي (Sequential/Incremental) وخامل (لا يُرسل بيانات أخرى)

الأسئلة العملية (تعتمد على الـ Lab الخاص بك)

ما يطلبه السؤال	الأمر	كيف تستخرج الإجابة
نتيجة Null Scan على الهدف	<code>sudo nmap -sN MACHINE_IP</code>	قارن بنتيجة <code>-sS</code> العادية؛ لاحظ الفارق بين <code>closed</code> و <code>open filtered</code>
نتيجة Xmas Scan	<code>sudo nmap -sX MACHINE_IP</code>	نفس الطريقة
نتيجة ACK Scan (filtered/unfiltered)	<code>sudo nmap -sA MACHINE_IP</code>	عمود <code>STATE: unfiltered</code> أو <code>filtered</code>
هل يمكن تجاوز الـ Firewall في Lab بـ FIN Scan؟	قارن <code>-sS</code> بـ <code>nmap -sF</code> على نفس المنفذ	إذا ظهر الـ Port "مفتوح/غير محجوب" في FIN وكان محجوبًا في SYN، فقد نجح التهرب

Room 4: Nmap Post Port Scans (4

الهدف: بعد معرفة ال Ports المفتوحة، نحتاج معلومات أعمق: ما الخدمة بالضبط؟ ما نظام التشغيل؟ هل توجد ثغرات معروفة؟ وكيف نحفظ كل هذا بشكل منظم؟

4.1 Service and Version Detection (الخيار -sV)

```
nmap -sV 10.10.10.5
nmap -sV --version-intensity 9 10.10.10.5 # فحص أعمق وأبطأ (9-0)
nmap -sV --version-light 10.10.10.5 # (منخفض intensity) فحص سريع وخفيف
nmap -sV --version-all 10.10.10.5 # جرب كل الاختبارات (شامل جدًا)
```

كيف يعمل من الداخل؟ رقم ال Port وحده لا يثبت الخدمة (قد يشغل أحدهم SSH على Port 8080 مثلاً). فيرسل Nmap سلسلة من ال **Probes** (استفسارات) ويقارن الردود بقاعدة بيانات ضخمة تسمى **nmap-service-probes**، ويحاول استخراج:

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.41 ((Ubuntu))

- اسم المنتج (Product)
- رقم النسخة (Version) — **أهم معلومة** لربطها بثغرات معروفة (CVE)
- نظام التشغيل الذي يستضيف الخدمة أحيانًا

4.2 OS Detection (الخيار -O)

```
sudo nmap -O 10.10.10.5
sudo nmap -O --osscan-guess 10.10.10.5 # تخمين أقرب تطابق حتى لو غير مؤكد
sudo nmap -O --osscan-limit 10.10.10.5 # الأقل Port مفتوح و Port فقط إذا وُجد
```

كيف يعمل من الداخل؟ يحتاج **root**. يرسل مجموعة اختبارات على مستوى منخفض جدًا (TTL الافتراضي، ترتيب خيارات TCP، سلوك IPID، حجم نافذة TCP Window Size...) ويقارنها بقاعدة **nmap-os-db** التي تحتوي بصمات آلاف الأنظمة.

```
Running: Linux 5.X
OS CPE: cpe:/o:linux:linux_kernel:5
OS details: Linux 5.0 - 5.4
Network Distance: 2 hops
```

تنبيه: OS Detection يحتاج **port** واحدًا مفتوحًا وآخر مغلقًا على الأقل ليعمل بدقة، وإلا يعطي . OS detection performed. No exact OS matches...

Nmap Scripting Engine (NSE) 4.3

أقوى ميزة في Nmap — محرك سكريبتات مكتوب بلغة **Lua** يوسّع قدرات الأداة من مجرد فاحص Ports إلى أداة Enumeration وحتى استغلال ثغرات بسيطة.

فئات السكريبتات (Categories)

الفئة	الوظيفة
auth	اختبار المصادقة (محاولة تجاوزها)
broadcast	اكتشاف أجهزة عبر Broadcast على الشبكة
brute	هجمات Brute-force على بيانات الدخول
default	المجموعة التي تعمل تلقائيًا مع -sC
discovery	استخراج معلومات إضافية عن الهدف والشبكة
dos	اختبار قابلية التعرّض لهجمات حجب الخدمة (احذر استخدامها!)
exploit	محاولة استغلال ثغرات فعليًا
external	يرسل بيانات لخدمات خارجية (مثل VirusTotal)
fuzzer	إرسال بيانات عشوائية لاكتشاف أخطاء
intrusive	قد تُسبب ضررًا أو تُكتشف — لا تُستخدم إلا بإذن صريح
malware	الكشف عن وجود Backdoors أو Malware
safe	آمنة ولا تؤثر على الهدف
version	تساعد في اكتشاف النسخة
vuln	البحث عن ثغرات معروفة والإبلاغ عنها

طرق التشغيل

```

nmap -sC 10.10.10.5 # (default) السكريبتات الافتراضية
nmap --script=default 10.10.10.5 # -sC نفس تأثير
nmap --script=vuln 10.10.10.5 # فئة كاملة
nmap --script=ftp-anon 10.10.10.5 # سكريبت محدد بالاسم
nmap --script=ftp-anon,http-title 10.10.10.5 # عدة سكريبتات
nmap --script="http-*" 10.10.10.5 # كل سكريبتات تبدأ بـ http
nmap --script=default,vuln 10.10.10.5 # دمج فئات
nmap --script-args user=admin,pass=admin 10.10.10.5 # تمرير معاملات للسكريبت

```

```

# تحديث قاعدة بيانات السكريبتات
sudo nmap --script-updatedb

# مكان السكريبتات على القرص (لينكس عادة)
/usr/share/nmap/scripts/

```

تحذير أمني: فئات `exploit` و `dos` و `brute` و `intrusive` قد تُعطّل الخدمة أو تُقفل حسابات بعد محاولات فاشلة متكررة. **لا تستخدمها إلا في بيئة فيها إذن صريح** (مثل Lab خاص بك).

4.4 الفحص الشامل التقليدي (الخيار -A)

```
sudo nmap -A 10.10.10.5
```

اختصار يفعل معًا: `-sV` (كشف النسخة) + `-O` (نظام التشغيل) + `-sC` (السكريبتات الافتراضية) + Traceroute. شامل وقوي لكنه بطيء وصاخب جدًا، لذلك يُفضّل في الـ Labs وليس في اختبارات تتطلب التخفي.

4.5 حفظ النتائج (Output Formats)

الخيار	الصيغة	الاستخدام
<code>-oN</code> <code>file.txt</code>	Normal	نفس ما تراه على الشاشة
<code>-oG</code> <code>file.txt</code>	Grepable	سطر واحد لكل هدف، سهل الفلترة بـ <code>grep / awk</code> (قديمة لكنها مفيدة سريعًا)
<code>-oX</code> <code>file.xml</code>	XML	للمعالجة الآلية ولتحويلها لتقرير HTML
<code>-oA</code> <code>basename</code>	الثلاثة معًا	ينتج <code>basename.nmap</code> و <code>gnmap</code> و <code>.xml</code> بضربة واحدة

```
sudo nmap -sS -sV -oA scan_results 10.10.10.5
# ينتج : scan_results.nmap / scan_results.gnmap / scan_results.xml

# قابل للمشاركة HTML إلى تقرير XML تحويل
xsltproc scan_results.xml -o scan_report.html
```

لماذا نحفظ النتائج دائمًا؟ في الاختبارات الحقيقية (وفي الـ CTF الطويلة) تفحص عشرات الأجهزة؛ حفظ النتائج يوفر مرجعًا تعود إليه بدل إعادة الفحص، ويتيح أتمتة المعالجة لاحقًا (مثل ربطها بأدوات أخرى).

4.6 منظور المهاجم والمدافع

المهاجم	المدافع
بعد اكتشاف المنافذ يشغل <code>-sV</code> و <code>-sC</code> لتحديد النسخ الدقيقة وربطها بـ CVE محددة (عبر <code>searchsploit</code> مثلاً)	يراقب حركة NSE المميزة (محاولات استعلام غير معتادة من نفس IP على بروتوكولات متعددة)
OS Detection يحدد نوع الهجمات المناسبة (Windows له ثغرات مختلفة عن Linux)	يُخفي أو يُعَدّل TTL/Banner للتشويش (Honeypots تفعل العكس: تخدع المهاجم بنظام وهمي)
توثيق النتائج يحتفظ بـ <code>-oA</code> لكل مرحلة؛ يبني عليها تقرير الاختراق (Pentest Report)	يحلل سجلات IDS بحثًا عن أنماط NSE لمعرفة ماذا فحص المهاجم بالضبط

4.7 حل أسئلة الـ Room 4

الأسئلة النظرية

السؤال	الإجابة
خيار كشف الخدمة والنسخة	<code>-sV</code>
خيار كشف نظام التشغيل	<code>-O</code>
خيار تشغيل السكريبتات الافتراضية	<code>-sC</code>
ما يعادل <code>-sC</code> ؟	<code>--script=default</code>
خيار الفحص الشامل (كل شيء معًا)	<code>-A</code>
ماذا يشمل <code>-A</code> ؟	Service Version + OS Detection + Default Scripts + Traceroute
اللغة التي كُتبت بها سكريبتات NSE	Lua
فئة السكريبتات التي تبحث عن ثغرات معروفة	vuln
فئة السكريبتات الآمنة وغير المؤذية	safe
فئة سكريبتات هجمات القاموس/التخمين	brute
فئة سكريبتات محاولة الاستغلال الفعلي	exploit
قاعدة بيانات بصمات أنظمة التشغيل	nmap-os-db
قاعدة بيانات بصمات الخدمات	nmap-service-probes
خيار حفظ النتيجة بصيغة عادية	<code>-oN</code>
خيار حفظ النتيجة بصيغة Grepable	<code>-oG</code>
خيار حفظ النتيجة بصيغة XML	<code>-oX</code>
خيار حفظ الثلاث صيغ دفعة واحدة	<code>-oA</code>
خيار تمرير معاملات (Arguments) لسكريبت NSE	<code>--script-args</code>
أمر تحديث قاعدة بيانات السكريبتات	<code>nmap --script-updatedb</code>

الأسئلة العملية (تعتمد على الـ Lab الخاص بك)

ما يطلبه السؤال	الأمر	كيف تستخرج الإجابة
نسخة الخدمة على منفذ معيّن	<code>nmap -sV -p PORT MACHINE_IP</code>	عمود <code>VERSION</code>
نظام التشغيل المُخَمَّن	<code>sudo nmap -O MACHINE_IP</code>	سطر <code>Running:</code> أو <code>OS details:</code>
نتيجة سكربت vuln معيّن	<code>nmap --script=vuln -p PORT MACHINE_IP</code>	يظهر CVE أو ثغرة إن وُجدت تحت اسم المنفذ
محتوى صفحة HTTP الرئيسية (العنوان)	<code>nmap --script=http-title -p 80 MACHINE_IP</code>	سطر <code>http-title:</code>
فحص شامل وحفظه	<code>sudo nmap -A -oA full_scan MACHINE_IP</code>	راجع ملف <code>full_scan.nmap</code>

Topic Transition Recap (5): مراجعة شاملة وخطة

عمل كاملة

هذا القسم الأخير في الموديول يربط كل شيء معًا. الفكرة أنك الآن قادر على بناء منهجية فحص كاملة (Scanning Methodology) بدل تذكر أوامر منفصلة.

5.1 المنهجية الكاملة خطوة بخطوة

```
# ===== المرحلة 1: اكتشاف الأجهزة الحية =====
sudo nmap -sn 10.10.10.0/24 -oN hosts_up.txt

# ===== المرحلة 2: فحص سريع لكل المنافذ (TCP) =====
sudo nmap -sS -p- --min-rate 5000 -T4 -oN all_ports.txt 10.10.10.5

# ===== المرحلة 3: فحص عميق فقط للمنافذ المفتوحة (أسرع وأدق) =====
# (استخرج أرقام المنافذ من نتيجة المرحلة السابقة، مثلًا: 22,80,445)
sudo nmap -sS -sV -sC -p22,80,445 -oN deep_scan.txt 10.10.10.5

# ===== لأشهر المنافذ UDP المرحلة 4 (اختياري): فحص =====
sudo nmap -sU --top-ports 20 -oN udp_scan.txt 10.10.10.5

# ===== المرحلة 5: نظام التشغيل + فحص شامل عند الحاجة =====
sudo nmap -O -oN os_scan.txt 10.10.10.5

# ===== المرحلة 6: سكريبتات موجهة حسب الخدمة المكتشفة =====
nmap --script="ftp-*" -p21 10.10.10.5
nmap --script=vuln -p80,443 10.10.10.5

# ===== المرحلة 7: توثيق كل شيء =====
sudo nmap -A -oA final_report 10.10.10.5
```

لماذا هذا الترتيب مهم؟ فحص كل الـ (Ports -p-) سريعًا أولًا ثم التعمق لاحقًا بـ -sC -sV فقط على المفتوح منها = توفير وقت هائل. فحص -p- -A من البداية على شبكة كاملة قد يأخذ ساعات.

5.2 خريطة ذهنية: أي خيار أستخدم متى؟

أريد أن...	استخدم
أعرف الأجهزة الحية على شبكتي المحلية (الأدق)	<code>sudo nmap -PR -sn <subnet></code>
أعرف الأجهزة الحية عبر الإنترنت (بعيدة)	<code>sudo nmap -PE -PS443 -sn <range></code>
أفحص كل منفذ TCP بسرعة	<code>sudo nmap -sS -p- --min-rate 5000</code>
أتهرب من Firewall بسيط	جرب <code>-sX</code> / <code>-sN</code> / <code>-sF</code> ثم قارن
أعرف دقة ال Firewall (stateful أم لا)	<code>sudo nmap -sA</code>
أعرف النسخة الدقيقة لخدمة	<code>nmap -sV -p<port></code>
أعرف نظام التشغيل	<code>sudo nmap -O</code>
أبحث عن ثغرات معروفة تلقائيًا	<code>nmap --script=vuln</code>
أخفي هويتي تمامًا	<code>sudo nmap -sI <zombie>:<port></code>
أوثق كل شيء لتقرير	<code>-oA basename</code>

5.3 سيناريو تطبيقي متكامل (مثال واقعي)

لنفترض أنك بدأت فحص جهاز CTF جديد (10.10.10.50) من الصفر، هذا هو تسلسل تفكيرك:

1. "هل الجهاز حي؟" - `ping -c1 10.10.10.50` أو `nmap -sn`.
2. "ما المفتوح؟" - `sudo nmap -p- --min-rate 5000 -T4 10.10.10.50` (سريع وشامل).
3. "رأيت Ports: 22, 80, 445. ما تفاصيلها؟" - `sudo nmap -sC -sV -p22,80,445 10.10.10.50`.
4. "Apache 2.4.41 = 80. هل توجد ثغرة معروفة؟" - `nmap --script=vuln -p80 10.10.10.50` أو `searchsploit apache 2.4.41`.
5. "445 تعني SMB. هل تسمح بدخول مجهول؟" - `nmap --script=smb-enum-shares,smb-os-discovery -p445 10.10.10.50`.
6. "هل فاتني شيء في UDP؟" - `sudo nmap -sU --top-ports 20 10.10.10.50`.
7. "وثق كل شيء" - أعد الخطوات المهمة بـ `-oA` واحفظ في مجلد المشروع.

هذا بالضبط ما يُقصد بـ "Topic Transition": الانتقال من معرفة أوامر منفردة إلى التفكير كمختبر اختراق يبنى قراره بناءً على نتيجة الخطوة السابقة.

Cheat Sheet (6): كل الأوامر في صفحة واحدة

اكتشاف الأجهزة

```
nmap -sL -n 10.10.10.0/24 # عرض الأهداف فقط (لا فحص)
sudo nmap -sn -PR 10.10.10.0/24 # ARP (شبكة محلية، الأذق)
sudo nmap -sn -PE 10.10.10.0/24 # ICMP Echo
sudo nmap -sn -PP 10.10.10.0/24 # ICMP Timestamp
sudo nmap -sn -PM 10.10.10.0/24 # ICMP Address Mask
sudo nmap -sn -PS22,80,443 10.10.10.0/24 # TCP SYN Ping
sudo nmap -sn -PA80 10.10.10.0/24 # TCP ACK Ping
sudo nmap -sn -PU53 10.10.10.0/24 # UDP Ping
```

فحص المنافذ الأساسي

```
nmap -sT 10.10.10.5 # TCP Connect (لا يحتاج root)
sudo nmap -sS 10.10.10.5 # TCP SYN (root الافتراضي مع)
sudo nmap -sU 10.10.10.5 # UDP Scan
sudo nmap -sS -p- 10.10.10.5 # كل الـ 65535 منفذ
sudo nmap -F 10.10.10.5 # أشهر 100 منفذ
nmap --top-ports 20 10.10.10.5 # أشهر 20 منفذ
sudo nmap -sS -p- --min-rate 5000 -T4 10.10.10.5 # سريع جدًا
```

فحص متقدم / تهريب

```
sudo nmap -sN 10.10.10.5 # Null Scan
sudo nmap -sF 10.10.10.5 # FIN Scan
sudo nmap -sX 10.10.10.5 # Xmas Scan
sudo nmap -sM 10.10.10.5 # Maimon Scan
sudo nmap -sA 10.10.10.5 # ACK Scan (رسم خريطة Firewall)
sudo nmap --scanflags SYNFIN 10.10.10.5 # أعلام مخصصة
sudo nmap -D RND:5 10.10.10.5 # عشوائية Decoys
sudo nmap --spooof-mac 0 10.10.10.5 # عشوائي MAC
sudo nmap -sI zombie_ip:port target_ip # Idle (Zombie) Scan
```

كشف الخدمات ونظام التشغيل والسكريبتات

```
nmap -sV 10.10.10.5 # كشف النسخة
sudo nmap -O 10.10.10.5 # كشف نظام التشغيل
nmap -sC 10.10.10.5 # السكريبتات الافتراضية
nmap --script=vuln 10.10.10.5 # بحث عن ثغرات
nmap --script=ftp-anon -p21 10.10.10.5 # سكريبت محدد
sudo nmap -A 10.10.10.5 # كل شيء معًا
```

الحفظ والتحكم في السرعة

```
sudo nmap -sS -sV -oA results 10.10.10.5 # حفظ بكل الصيغ
nmap -T4 10.10.10.5 # (CTF الأنسب للـ) سريع
nmap --min-rate 5000 10.10.10.5 # معدل إرسال مرتفع
nmap -n 10.10.10.5 # (أسرع) DNS lookup بدون
nmap --reason 10.10.10.5 # اعرض سبب كل حالة
nmap --open 10.10.10.5 # اعرض المفتوح فقط
```

(7) أخطاء شائعة وحلولها

المشكلة	السبب المحتمل	الحل
<code>Host seems down</code> رغم تأكيدك أن الجهاز شغال	Firewall يحجب ICMP Ping	أضف <code>-Pn</code> لتخطي الاكتشاف والفحص مباشرة
النتائج بطيئة جدًا	فحص كل الـ Ports بالإعدادات الافتراضية	استخدم <code>--min-rate 5000</code> أو <code>T4</code> أو فحص <code>--top-ports</code> أولًا
<code>-sS</code> لا يعمل / رسالة تتعلق بالصلاحيات	تشغيل بدون root	أضف <code>sudo</code> قبل الأمر
منافذ UDP كلها <code>open\ filtered</code>	طبيعة UDP (لا رد لا يعني شيئًا مؤكدًا)	أضف <code>-sV</code> لإرسال Payloads تستثير ردًا حقيقيًا
Null/FIN/Xmas تعطي كل شيء "closed" أو "open" بلا تمييز	الهدف Windows ولا يتبع RFC 793	هذه الفحوصات غير موثوقة ضد Windows، استخدم <code>-sS</code> بدلًا منها
<code>-0</code> تعطي "No exact OS matches"	لا يوجد Port مفتوح وآخر مغلق كافٍ للمقارنة	افحص Ports أكثر، أو استخدم <code>--ossan-guess</code>
نتائج مختلفة بين كل تشغيل	الشبكة غير مستقرة أو IDS يتدخل	أضف <code>--max-retries 2</code> وخفف السرعة بـ <code>-T2</code>
<code>--script=vuln</code> بطيء جدًا	يجرب سكريبتات كثيرة على منافذ كثيرة	حدد المنافذ بـ <code>-p</code> بدل فحص شامل

(8) المراجع ومصادر التعلّم

- **الدليل الرسمي لـ Nmap (Nmap Reference Guide):** <https://nmap.org/book/man.html>
 - **كتاب Nmap الرسمي الكامل مجاًً أونلاين:** <https://nmap.org/book/toc.html>
 - **قاعدة بيانات سكريتات NSE الرسمية:** <https://nmap.org/nsedoc/>
 - **موقع التدريب الرسمي للتجربة القانونية:** scanme.nmap.org
 - **TryHackMe — موديول Nmap:** الرومات الخمسة التي يغطيها هذا الملف
 - **RFC 793 (مواصفة TCP الأصلية):** مرجع لفهم سبب عمل Null/FIN/Xmas Scans
 - **searchsploit (من Exploit-DB):** للربط بين نتائج `-sV` والثغرات المعروفة
 - **HackTricks — قسم Pentesting Network:** مرجع ممتاز لأوامر Nmap العملية بالسيناريوهات
-

(9) قاموس المصطلحات

المصطلح	الشرح
Host Discovery	مرحلة تحديد الأجهزة الحيّة على الشبكة قبل فحص الـ Ports
Port Scanning	إرسال حزم لكل Port لمعرفة حالته (مفتوح/مغلق/محجوب)
Three-Way Handshake	عملية بدء اتصال TCP: SYN -> SYN/ACK -> ACK
Stateful Firewall	يتتبع حالة الاتصال كاملة (يعرف أن ACK بلا SYN سابق أمر غريب)
Stateless Firewall	يفلتر فقط بناءً على رقم Port/IP بدون تتبع حالة الاتصال
IDS / IPS	أنظمة كشف/منع التسلل التي تراقب حركة المرور المشبوهة
NSE	Nmap Scripting Engine، محرك السكريبتات المبني بلغة Lua
CVE	معرف موحد عالميًا لثغرة أمنية معروفة
Zombie Host	جهاز خامل يُستخدم كوسيط في هجوم Idle Scan
IPID	رقم تعريف فريد لكل حزمة IP، يُستخدم لتتبع التسلسل في Idle Scan
Banner Grabbing	استخراج معلومات الخدمة من الرسالة الترحيبية (Banner) التي ترسلها عند الاتصال
Enumeration	جمع معلومات تفصيلية عن خدمة أو نظام بعد اكتشافه

كلمة أخيرة

Nmap أداة ضخمة، وهذا الدليل يغطي كل ما تحتاجه لتبدأ قوياً وتفهم **لماذا** يعمل كل أمر وليس فقط **كيف** تكتبه. تدرّب على scanme.nmap.org وعلى أجهزة TryHackMe/HackTheBox الخاصة بك، واحفظ دائماً: **الفهم > الحفظ**.

بالتوفيق في رحلتك في الـ **Penetration Testing** 